

Muhammad Saad Salman

Red_teamer-AKTI

Web App Pentesting Methodologies:

What is web pentesting?

It is comprehensive security assessments aimed to identify weaknesses and vuln in web applications.

It involves simulating real-world attacks to evaluate web vulnerabilities and exploiting them.

Methodologies:

Importance of These Methodologies:

Consistency and Standarization:

It ensures that penetration tests are performed consistently across different web apps and projects. It provides standardized tests, tools, and procedures ensuring all the necessary areas are thoroughly tested.

Comprehensive Coverage:

Efficiency and Tlme Management:

Through Identification of Vulnerabilities:

Risk Prioritization: Based on the portential impact of vuln on the web application.

Effective Reporting and Communication

First we must know what is **Ad-hoc testing**?

Ad-hoc testing is an informal, unstructured testing approach performed without predefined test cases, scripts, or documentation. The tester relies on intuition, experience, and domain knowledge to discover defects.

It is often called “random testing”, but in practice it is experience-driven exploratory probing, not pure randomness.

Now moving towards the Methodologies:

S.No	Phases	Objectives
1	Pre-Engagements	- Defining scope/objective of the pentesting including web apps, URLs and functions to be tested. - Obtain proper authorization from the owner - Gather relevant info about the target ie tech used, user roles and business-critical functionalities
2	Info Gathering/Recon	- Performing passive recon on publicly available data and its infrastructure. - Enum sub-directories, sub-domains, and files to discover hidden/sensitive data. - Using tools like NMAP for identification of open ports and services. - Google dorking
3	Threat Modeling	- Analyze app's architecture and data flow to identify potential threats and attack vectors. - Build an attack surface model to understand how attacker can interact with the application. - Identify potential risk areas and prioritizing efforts.
4	Vulnerability Scanning	- Use automated tools like Burp/OWASP-ZAP to identify common security flaws. - Verify and validate the scan results to eliminate false-positives and false-negatives.
5	Manual Testing & Exploitation	- Perform manual tests to validate and exploit identified vuln in the app. - Tests for input validation issues, auth bypass, authorization flaws and business logic vulnerabilities - Exploiting flaws and to demonstrate their impact and potential risks
6	Auth&Authorization Testing	- Identifying flaws in passwd policies,, session mgmt and account lockout procedures. - Eval the app's access control to ensure users cant access the sensi data
7	Session Management Testing	- Eval app's session mgmt mechanism to prevent session fixation, session hijacking and session related attacks. - Check for session timeout and proper session handling

